

EXPLOITED VULNERABILITY ADVISORY: CVE-2026-67277

Summary

CVE-2026-67277 in MikroTik RouterOS is being actively exploited in the wild. RouterOS accepts a "related" btest connection before the corresponding primary session has completed authentication. An unauthenticated client can use this state to start an IPv4 UDP test. With "random-data=false", the sender transmits an uninitialized tail from a kernel packet buffer. A separate unchecked, inverted packet-size interval causes unsigned integer underflow, anomalously large fragmented output, and can restart the RouterOS kernel.

This issue was fixed in versions: 6.49.21 (Long-term), 7.23.4 (Long-term) and 7.24.2 (Stable) CISA requires federal remediation by 2026-09-13; under the CRA, exploitation of an affected product must be reported within 24 hours.

What we know

- **CVE:** CVE-2026-67277
- **Affected:** MikroTik RouterOS
- **Exploitation:** Actively exploited, added to CISA KEV on 2026-09-10
- **Severity:** CVSS 8.8 High, Network-exploitable, no privileges required, no user interaction
(CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:H/SC:N/SI:N/SA:N/E:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MAT:X/MPR:X/MUI:X/MVC:X/MVI:X/MVA:X/MV:)
- **Exploitation likelihood (EPSS):** 0%
- **Weakness:** CWE-306

Recommended action

Patch CVE-2026-67277 by 2026-09-13. If you cannot patch immediately, restrict network access to the affected service now (segment it, put it behind a VPN, or take it offline) until you can patch. If you ship an affected product, be ready to file the CRA 24-hour report the moment you find it exploited.

Sources: CISA Known Exploited Vulnerabilities, NIST NVD. Public data; an advisory of active exploitation, not an incident report. Verify applicability to your estate before acting.